

Dans les entrailles d'une supply chain attack REX de Shai-Hulud 2.0 et enseignements

Maxime Dupont

OVHcloud

Agenda

1. **L'attaque** — contexte, chronologie et mécanisme technique
2. **Les enseignements** — détection, remédiation et protection
3. **Questions / Réponses**





🦩 Maxime Dupont 🦩

Partie 1 – L'attaque

C'est quoi une supply chain attack ?

Vous n'attaquez pas la cible directement. Vous compromettez **un de ses fournisseurs**.

1. Un attaquant compromet un paquet npm populaire
2. Le paquet npm est installé par un développeur / une CI
3. Cela donne accès aux secrets, aux tokens et aux infra cloud

Shai-Hulud 2.0 — "The Second Coming"

Une première attaque a eu lieu en septembre 2025. Deux mois plus tard, une deuxième version voit le jour.

Shai-Hulud 2.0 — "The Second Coming"

Une première attaque a eu lieu en septembre 2025. Deux mois plus tard, une deuxième version voit le jour.

Métrique	Valeur
Paquets npm compromis	796
Téléchargements hebdo cumulés	20 millions+
Repos GitHub exposés	25 000+

Shai-Hulud 2.0 – "The Second Coming"

Une première attaque a eu lieu en septembre 2025. Deux mois plus tard, une deuxième version voit le jour.

Métrique	Valeur
Paquets npm compromis	796
Téléchargements hebdo cumulés	20 millions+
Repos GitHub exposés	25 000+

Anatomie technique — Stage 0

Compromettre un premier package npm (ingénierie sociale)

Anatomie technique — Stage 1

Le paquet compromis contient un **preinstall script** dans `package.json` :

```
{  
  "scripts": {  
    "preinstall": "node setup_bun.js"  
  }  
}
```

Anatomie technique — Stage 1

Le paquet compromis contient un **preinstall script** dans `package.json` :

```
{  
  "scripts": {  
    "preinstall": "node setup_bun.js"  
  }  
}
```

Pourquoi `preinstall` ?

Anatomie technique — Stage 1

Le paquet compromis contient un **preinstall script** dans `package.json` :

```
{  
  "scripts": {  
    "preinstall": "node setup_bun.js"  
  }  
}
```

Pourquoi `preinstall` ?

Anatomie technique — Stage 2

`setup_bun.js` télécharge et exécute `bun_environment.js` — un fichier de **10 Mo**, obfusqué.

Anatomie technique — Stage 2

`setup_bun.js` télécharge et exécute `bun_environment.js` — un fichier de **10 Mo**, obfusqué.

Ce qu'il fait

Anatomie technique — Auto-réplication

S'il trouve un token npm valide → il **republie** les paquets accessibles avec le payload malicieux inclus. Le ver se propage.

Anatomie technique — Exfiltration

pas de serveur C2 (Command and Control) classique.

1. Création d'un repo GitHub public "Sha1-Hulud: The Second Coming"
2. Push les secrets volés

Anatomie technique — Le payload destructif

Si le malware ne trouve **ni token npm, ni token GitHub** :

- Destruction du répertoire home de l'utilisateur
- Écrasement sécurisé + suppression de chaque fichier accessible en écriture

C'est la première supply chain attack npm avec un mécanisme de **sabotage punitif**.

Partie 2 – Les enseignements

Pourquoi ça nous concerne ?

On utilise (tous) npm et si on n'utilise pas npm, on en utilise d'autres

Luck isn't a security strategy.

Ryan Sobol — Principal Software Engineer at the Seattle Times

Comment l'attaque a été détectée ?

Comment l'attaque a été détectée ?

Ecosystème

Connaissez votre écosystème !

Comment l'attaque a été détectée ?

Ecosystème

Connaissez votre écosystème !

Veille technique

Comment l'attaque a été détectée ?

Ecosystème

Connaissez votre écosystème !

Veille technique

Remédiation — Les premières heures

Si vous découvrez que vous êtes compromis :

Action	Détail
Ne pas supprimer le repo malveillant	Le privatiser immédiatement pour stopper l'exposition
Désactiver les workflows malicieux	Vérifier tous les self-hosted runners

Se protéger — les basiques

- Utiliser des jetons scoppés (local / CI)
- Obliger la signature des commits
- Utiliser des passphrase
- Toujours publier depuis une CI
- Trusted Publisher

Se protéger — package manager

Le choix du package manager est la **première ligne de défense**.

Se protéger — package manager

Le choix du package manager est la **première ligne de défense**.

Choix du manager de paquets

Gestionnaire de paquets	Version	Date
Yarn	v2.0	Jan. 2020

Se protéger — gérer les exceptions

Contrôler quels paquets sont autorisés à exécuter des lifecycle scripts.

Se protéger — gérer les exceptions

Contrôler quels paquets sont autorisés à exécuter des lifecycle scripts.

Gestionnaire de paquets	Paramètre	Disponible depuis
Yarn	<code>enableScripts</code> (per-dep)	v2.0 (Jan. 2020)
Bun	<code>trustedDependencies</code> (per-dep)	v1.1 (Avr. 2024)
pnpm	<code>onlyBuiltDependencies</code>	v9.1 (Mai 2024)
npm	-	-

Se protéger — gérer les exceptions

Contrôler quels paquets sont autorisés à exécuter des lifecycle scripts.

Gestionnaire de paquets	Paramètre	Disponible depuis
Yarn	<code>enableScripts</code> (per-dep)	v2.0 (Jan. 2020)
Bun	<code>trustedDependencies</code> (per-dep)	v1.1 (Avr. 2024)
pnpm	<code>onlyBuiltDependencies</code>	v9.1 (Mai 2024)
npm	-	-

Se protéger — minimumReleaseAge

Bloquer l'installation de versions publiées trop récemment — le temps que la communauté détecte les paquets malicieux.

```
# .npmrc (pnpm)  
minimum-release-age=3d  
minimum-release-age-exclude=my-org
```

Les 796 paquets compromis ont été publiés et détectés en **48h** — un délai de 3 jours les aurait tous bloqués.

Se protéger — trustPolicy

Ce contrôle bloque l'installation lorsqu'une version d'un package a une authentification plus faible que les versions publiées précédemment.

Gestionnaire de paquets	Paramètre	Disponible depuis
pnpm	trustPolicy: "no-downgrade"	v9 (~2024)
npm	—	—
Yarn	—	—

Se protéger — npm et CI/CD

Si vous utilisez npm :

```
npm config set ignore-scripts true      # Désactive tous les lifecycle scripts  
npm install --ignore-scripts            # Par installation
```

En CI/CD, toujours builder avec `--ignore-scripts` et exécuter les scripts nécessaires manuellement après audit.

Résumé — Ce qu'il faut retenir

1. npm est un vecteur d'attaque majeur
2. Les preinstall scripts sont dangereux
3. Les tokens sont la cible n°1
4. La CI/CD est une surface d'attaque
5. Security by design
6. Shai-Hulud 2.0 a introduit le sabotage

Questions ?

Posez vos questions — sur l'attaque, les mesures de protection.

Pour aller plus loin

- [pnpm — How We're Protecting Our Newsroom from npm Supply Chain Attacks](#)
- [Microsoft — Guidance for detecting and defending](#)
- [Wiz — 25K+ Repos Exposed](#)
- [Unit42 — npm Supply Chain Attack](#)
- [Check Point — Most Aggressive NPM Supply Chain Attack of 2025](#)